Zephyr Project

IT-Schulungen.com
Technology & Transformation

Secure Boot und Schlüsselverwaltung

Root of Trust, Vertrauenskette und kontrollierter Schlüssellebenszyklus

5.08

Vertrauen beginnt bei einem festen Anker

ROOT OF TRUST

Unveränderlicher Anker

ROM, OTP oder geschützter Speicher startet die erste Prüfung.

CHAIN OF TRUST

Stufe prüft Stufe

Jede Komponente authentisiert die nächste vor der Übergabe.

POLICY

Vertrauen begrenzen

Nur freigegebene Schlüssel, Versionen und Images werden akzeptiert.

Secure Boot ist eine durchgängige Prüfkette, nicht nur eine einzelne Signaturprüfung.

Prüfkette vom Reset bis zur Anwendung

BOOT CHAIN

```
ROOT OF TRUST → BOOTSTUFE → MCUboot → ZEPHYR
```

SoC / ROM	prüft die erste veränderliche Bootstufe
BOOTLOADER	prüft seinen Nachfolger vor der Übergabe
MCUBOOT	validiert Header, Hash, Signatur und Versionspolitik
ANWENDUNG	startet erst nach erfolgreicher Prüfung der Kette

Eine ungeprüfte Übergabe unterbricht die Vertrauenskette.

SoC Secure Boot und MCUboot ergänzen sich

`SoC Secure Boot`	authentisiert die frühe Bootstufe aus einem Hardwareanker
`MCUboot`	authentisiert Anwendungsimages und Updatekandidaten
`Vertrauensgrenze`	öffentlicher Schlüssel liegt in der prüfenden Komponente
`Updatepolitik`	Version, Security Counter und Slotstatus beeinflussen die Auswahl
`Übergabe`	nur eine akzeptierte Stufe erhält die Ausführung

Jede Prüfstufe schützt ihren eigenen Übergang; keine einzelne Stufe deckt die gesamte Kette ab.

Schlüsselrollen strikt trennen

SCHLÜSSELROLLEN

PRIVATE KEY → SIGNATUR

PUBLIC KEY → VERIFIKATION

01 Privater Schlüssel

bleibt im kontrollierten Signierbereich und verlässt ihn nicht.

02 Öffentlicher Schlüssel

wird in der prüfenden Bootkomponente verankert.

03 Schlüsselreferenz

KEYHASH verbindet Image und Vertrauensanker.

Der Bootloader benötigt keinen privaten Produktionsschlüssel.

Schlüsselklassen folgen dem Produktlebenszyklus

UMGEBUNGEN

ENTWICKLUNG → TEST → RELEASE → PRODUKTION

01 Trennung

Jede Umgebung erhält eigene Schlüssel und klar definierte Vertrauensregeln.

02 Berechtigung

Nur benötigte Rollen dürfen Signiervorgänge anfordern oder freigeben.

Öffentliche Entwicklungsschlüssel dürfen niemals als Produktionsvertrauen dienen.

Signierbetrieb mit minimalen Berechtigungen

Offline-Signierung oder zentraler Dienst trennt Build und Schlüsselzugriff

01

Anfordern

Artefakt und Metadaten eindeutig übergeben

02

Freigeben

Rolle und Releasekontext prüfen

03

Signieren

privaten Schlüssel isoliert verwenden

04

Veröffentlichen

signiertes Image und Prüfdaten bereitstellen

05

Auditieren

Hash, Version, Schlüssel-ID und Vorgang protokollieren

Der Build erzeugt das Artefakt; die Signierinstanz erteilt die kryptografische Freigabe.

Rotation, Widerruf und Anti-Rollback

01	`Rotation`	neuen Prüfschlüssel vor dem Wechsel kontrolliert verankern
02	`Kompromittierung`	alten Schlüssel aus dem Vertrauenssatz entfernen und neu signieren
03	`Security Counter`	verhindert die Rückkehr zu Images unterhalb der erlaubten Sicherheitsstufe

Schlüsselwechsel und Counter müssen als gemeinsamer, unterbrechungssicherer Ablauf geplant werden.

Signatur, Verschlüsselung und Laufzeitschutz

SIGNATUR

Authentizität

Belegt Herkunft und Integrität der gebundenen Imagebytes.

VERSCHLÜSSELUNG

Vertraulichkeit

Schützt Imageinhalte bei Speicherung oder Übertragung.

LAUFZEIT

Eigene Schutzebene

Ein gültig signiertes Image kann weiterhin Laufzeitfehler enthalten.

Secure Boot kontrolliert, was startet; Laufzeitschutz kontrolliert, was danach geschehen darf.

Secure Boot: Technik und Betrieb

VERTRAUENSMODELL

ANKER → PRÜFKETTE → IMAGEPOLITIK

SCHLÜSSEL → ROLLEN → ROTATION

COUNTER → ANTI-ROLLBACK

01 Technik

Bootstufen, öffentliche Schlüssel, Signaturen und Security Counter erzwingen Regeln.

02 Betrieb

Rollen, isolierte Signierung, Rotation und Reaktion auf Kompromittierung halten sie wirksam.

Eine belastbare Vertrauenskette verbindet Hardwareanker, Imageprüfung und Schlüssellebenszyklus.